# Chat Gateway API 연동 가이드

MVC·Tomcat 기반 Controller → Service → Client 구조입니다. 일반 HTTP는 원문 응답, SSE는 SseEmitter로 전달하며 Spring Cloud Gateway 중계는 사용하지 않습니다.

프론트 및 Agent B/E 공유용 | 2026-10-21 | OpenAPI 1.0.0

G/W는 인증과 HTTP/SSE 중계를 담당합니다. 대화 소유권·금융 업무 실행은 Agent B/E가 담당합니다. 이 문서는 현재 구현 기준이며 실제 PFC·세션 서비스 연동 완료를 의미하지 않습니다.

## 01 · 프론트 호출 순서

| 상황 | 처리 순서 |
| --- | --- |
| 첫 진입 | threadId 생성 → POST session → 응답 threadId로 POST chat |
| 새 대화 | 기존 SSE 종료 → 새 threadId → POST session/restart (200) |
| 게스트 로그인 | 플랫폼 로그인 → _O 쿠키 발급 → 같은 threadId로 chat + X-Requested-Login: true → 회원 전환 |
| 쿠키 유실 | 회원: 플랫폼 재인증 후 기존 threadId로 새 세션. B/E 소유권 확인 필수. 게스트: 새 threadId로 새 대화 |
| 버튼 클릭 | POST click으로 시나리오 진행 상태 전달. G/W가 활동 연장 후 자체 JSON 로그 기록, 200 |
| 추가 인증 | SDK 결과 → X-Mfa-Result → POST chat resume. B/E가 업무 실행 |

## 공통 규칙

GW 자체 성공은200으로 통일합니다. B/E의 HTTP 상태·본문은 그대로 전달합니다. GW 경로/메서드 오류404/405와 예상하지 못한 서버 오류500은 유지합니다.

세션 쿠키: __Host-sh-session / HttpOnly / Secure / SameSite=Lax / Path=/. 브라우저가 관리하며 JS로 쿠키를 읽거나 덮어쓰지 않습니다. 동일 Origin에서 요청합니다.

자동완성 조회 외 변경 요청은 Idempotency-Key가 필요합니다. 새 요청은 새 키, 동일 재전송은 같은 키입니다. 세션 신규 생성 재시도는400일 수 있으며 이전 SID 응답 재생을 보장하지 않습니다.

5분 비활동 만료. 응답의 X-Chat-Auth-Expires-At와 X-Server-Time은 UTC epoch milliseconds입니다. GET·heartbeat·SSE 수신만으로 연장하지 않습니다. GET session과 auth/activity는 제거됐습니다.

# 02 · 세션 생성과 새 대화

## POST /api/auth/session

| 입력 위치 | 이름 / 형식 / 필수 여부 |
|---|---|
| query | channelId / string / 조건부 또는 선택 |
| query | threadId / string / 조건부 또는 선택 |
| header | Idempotency-Key / string / 필수 |

응답: 200 (그 외 오류는 공통 오류 규격 참조)

channelId: 신규 인증에 필요, 기존 세션은 생략 가능. threadId: FE가 지정하며 신규 생성에서 생략하면 GW가 UUID를 만들어 반환합니다. 유효 세션과 다른 threadId를 지정하면400입니다.

유효 회원 세션은 _O보다 우선합니다. 신규 생성에만 _O 3종을 PFC로 검증합니다. 기존 게스트는 이 API에서 회원으로 전환하지 않습니다.

## 성공 응답 (200)

{"userType":"GUEST", "expiresAt":1792454700000,
"serverTime":1792454400000, "threadId":"thread-1"}

MEMBER/GUEST를 반환합니다. 신규 생성에 세션 Set-Cookie, 회원 응답에는 홈페이지 연동용 _I 3종을 설정합니다.

## POST /api/auth/session/restart

| 입력 위치 | 이름 / 형식 / 필수 여부 |
|---|---|
| header | Idempotency-Key / string / 필수 |
| JSON | threadId / string / 필수 |

응답: 200 (그 외 오류는 공통 오류 규격 참조)

유효 회원의 인증·channelId를 유지하고 SID와 threadId를 교체합니다. _O/PFC 재인증은 필요하지 않습니다. 게스트는 새 게스트로 시작하며 추가 인증 결과는 승계하지 않습니다. 성공200 형식은 위와 같고 _I는 발급하지 않습니다.

FE는 기존 SSE를 종료한 뒤 새 threadId를 전달합니다. 동일 재시도는 같은 키·threadId를 사용합니다. 이전/새 쿠키 모두 같은 결과를 반환하며 만료를 연장하지 않습니다. 만료·폐기·쿠키 부재는401이며 재인증이 필요합니다.

## 만료·쿠키 유실 경계

채팅·클릭에서 세션 부재/만료는401입니다. 세션 POST는 자연 만료된 ACTIVE 기록이 남으면 신규 생성이 가능합니다. 폐기 또는 알 수 없는 SID는401입니다. 쿠키 없는 재인증에서 기존 SID/guestSubject를 복원하지 않습니다.

# 03 · 채팅/SSE와 클릭 로그

## POST /api/chat

| 입력 위치 | 이름 / 형식 / 필수 여부 |
|---|---|
| header | X-Requested-Login / string / 조건부 또는 선택 |
| header | Idempotency-Key / string / 필수 |
| header | X-Mfa-Result / string / 조건부 또는 선택 |
| JSON | threadId / string / 필수 |

응답: 200 (그 외 오류는 공통 오류 규격 참조)

게스트 로그인 전환은 X-Requested-Login: true에서만 수행합니다. 생략/false는 _O가 있어도 게스트 유지. true에서 _O 누락·검증 실패 시 게스트 유지 및 B/E 호출 없음. 성공 시 PID·회원 유형 변경, SID 교체, threadId와 기존 게스트 식별자 유지, 사용한 _O 삭제. 유효 회원은 재인증하지 않습니다. 중복·true/false 외 값은400입니다.

본문 예: {"threadId":"thread-1", "text":"한도 안내"}
threadId 외 메시지 필드와 SSE 이벤트 구조는 B/E 계약으로 확정합니다. 원문 JSON 최대1MiB를 /internal/v1/chat으로 중계합니다.

인증 오류는 SSE 전 JSON으로 반환합니다. 스트림 시작 후 오류는 연결 종료로 처리합니다. 세션이 자연 만료돼도 이미 시작한 답변은 계속 전달합니다. B/E heartbeat 간격은 읽기 대기 기본30초보다 짧아야 합니다.

## POST /api/click

| 입력 위치 | 이름 / 형식 / 필수 여부 |
|---|---|
| header | Idempotency-Key / string / 필수 |
| JSON | threadId / string / 필수 |
| JSON | scenarioId / string / 필수 |
| JSON | state / string / 필수 |
| JSON | component / string 또는 object / 필수 |
| JSON | buttonInfo / object / 선택 |

응답: 200 (그 외 오류는 공통 오류 규격 참조)

예: {"threadId":"thread-1", "scenarioId":"limit-increase",
"state":"amount-selected", "component":{"id":"next", "type":"button"}}

scenarioId/state는 비어 있지 않은 문자열, component는 식별 문자열 또는 객체입니다. 추가 필드는 기록하지 않습니다. 세션 threadId와 다르면400입니다.

Gateway에서 JSON 로그 기록 후200, {"status":"OK"}와 만료 헤더를 반환합니다. B/E를 호출하지 않습니다. 로그는 수신 시각·키·대화·채널·사용자 유형·시나리오·상태·컴포넌트를 포함합니다. 기존 AUDIT 수집 형식(message.name=click)을 사용합니다. sessionId는 threadId, userId는 검증된 회원 PID이며 게스트는 null입니다. buttonInfo는 선택 입력입니다. 쿠키·인증값·임의 추가 필드는 기록하지 않으며 component와 버튼 필드에 민감정보를 보내지 마세요. 재시도 로그는 중복될 수 있어 channelId/threadId/key로 식별합니다. 200는 수집 시스템 영구 저장을 보장하지 않습니다. 클릭에는 인증 문맥·_I를 발급하지 않습니다.

# 04 · 이력/도구와 공통 오류

## GET /api/chat/threads

응답: 200 (그 외 오류는 공통 오류 규격 참조)

## GET /api/chat/threads/{tid}/messages

| 입력 위치 | 이름 / 형식 / 필수 여부 |
|---|---|
| path | tid / string / 필수 |

응답: 200 (그 외 오류는 공통 오류 규격 참조)

## GET /api/chat/threads/{tid}/artifacts/{aid}

| 입력 위치 | 이름 / 형식 / 필수 여부 |
|---|---|
| path | tid / string / 필수 |
| path | aid / string / 필수 |

응답: 200 (그 외 오류는 공통 오류 규격 참조)

GET은 세션을 연장하지 않습니다. 각 대화의 소유권은 B/E가 확인합니다. G/W는 /api/chat 접두사를 /internal/v1/chat으로 바꿔 중계합니다.

## POST /api/chat/threads/{tid}/tools/{tool}

| 입력 위치 | 이름 / 형식 / 필수 여부 |
|---|---|
| path | tid / string / 필수 |
| path | tool / string / 필수 |
| header | Idempotency-Key / string / 필수 |

응답: 200 (그 외 오류는 공통 오류 규격 참조)

도구 본문·성공 응답 규격은 B/E 계약을 따릅니다. 원문 중계하며 유효 세션의 threadId와 tid가 일치해야 합니다.

| GW 오류 | 프론트 처리 |
|---|---|
| 400 INVALID_ARGUMENT | 입력 형식·크기·threadId·키 충돌 확인 |
| 401 UNAUTHENTICATED | 세션 만료·부재: 재인증 안내 |
| 403 PERMISSION_DENIED | 권한 또는 추가 인증 실패 확인 |
| 503 UNAVAILABLE | 의존 서비스 장애·시간 초과. 성공으로 추정하지 않음 |

오류 예: {"error":{"code":403,"status":"PERMISSION_DENIED",
"message":"","failedAuthReqIds":["ar_1"]}}
failedAuthReqIds는 항목별 인증 실패 시 본인의 알려진 요청에만 포함됩니다.

# 05 · 추가 인증 resume와 B/E 책임

## 프론트: SDK 완료 후 채팅 resume

X-Mfa-Result는 padding 없는 base64url(UTF-8 JSON 배열) 헤더 하나입니다. 기본 최대8건, 인코딩4096자입니다. JSON 원문을 헤더에 직접 넣지 않습니다.

〔{"authReqId":"ar_1","tranID":"T001",
"txId":"X001","method":"FINANCE_CA"},
{"authReqId":"ar_2","tranID":"T002","method":"SHINHAN"}〕

txId 없는 수단은 생략합니다. G/W는 전부 검증 후 세션 서비스에 원자 소비를 요청합니다. 실패하면 아무것도 소비하지 않고403, 성공하면 검증된 authReqId를 B/E에 전달합니다. 실제 PFC는 비소비 검증 계약이 필요합니다.

## 재시도·기한

동일 세션·키·목적지·본문·인증 목록의 재시도는 소비 영수증을 재사용하며 기한을 연장하지 않습니다. 등록 기본10분, 검증 결과 기본2분과 플랫폼/등록 기한 중 짧은 값을 적용합니다. 부분 실패 중 성공 항목의 최초 검증 시각은 저장하지 않으므로 더 엄격한2분 정책은 추가 합의가 필요합니다.

| B/E 수신 헤더 | 의미 |
|---|---|
| X-Authenticated-User-Id / User-Type / Channel-Id | 검증된 회원 또는 게스트 신원. 각 헤더명에 X-Authenticated- 접두사 사용 |
| X-Authenticated-Guest-Id | 현재 또는 회원 전환 전 게스트 신원. 처음부터 회원이면 없음 |
| X-Auth-Context | 회원+threadId 요청에만 발급. 게스트·목록·클릭 제외. 브라우저에 전달 금지 |
| X-Verified-Auth-Requests | 이번 resume에서 검증·소비한 authReqId 목록. 외부 위조값 제거 후 생성 |
| Authorization / Idempotency-Key | GW→B/E 서비스 Bearer / 요청 재전송 식별 키 |

B/E는 대화 소유권, 업무에 필요한 인증 ID 전체, 내용 버전·해시·업무 기한을 확인해야 합니다. 금융 업무 실행·중복 방지·결과 보관은 B/E 책임입니다. 인증 헤더가 없는 일반 채팅이 업무 인증을 대신하지 않습니다.

# 06 · 자동완성 조회

## POST /api/chat/auto

| 입력 위치 | 이름 / 형식 / 필수 여부 |
|---|---|
| JSON | queryText / string / 필수 |
| JSON | size / integer / 선택 |
| JSON | channel / string / 선택 |

응답: 200 (그 외 오류는 공통 오류 규격 참조)

이전 챗봇 계약을 유지합니다. queryText는 공백 불가, size 기본10/최대1000, channel 기본 sol-chat. 유효 게스트·회원 세션 필요, 세션 연장과 Idempotency-Key는 없습니다. 같은 Origin으로 요청합니다.

Eureka search-autocomplete-service의 POST /api/autocomplete/chat으로 호출합니다. 브라우저 쿠키와 인증 헤더는 검색 서비스로 전달하지 않습니다.

200 응답: {"code":"SUCCESS","message":"성공","data":{"totalCount":0,"chatResponse":[]}}

chatResponse 항목: highlight, score, auto_result, weight, boost, nori_result, ngram_result. highlight HTML 렌더링 시 FE에서 허용 태그만 사용합니다. 오류: 입력400, 세션401, 검색 서비스 실패503.

X-Verified-Login은 사용하지 않으며 외부 입력은 제거합니다. 로그인 처리는 X-Requested-Login:true와 검증된 신원 헤더를 사용합니다.

# 07 · B/E의 인증 요청 등록

B/E 전용 API입니다. 브라우저는 호출하지 않습니다. 서비스 Bearer와 유효한 X-Auth-Context가 필요합니다.

## POST /internal/v1/auth/operations

| 입력 위치 | 이름 / 형식 / 필수 여부 |
|---|---|
| header | X-Auth-Context / string / 필수 |
| JSON | key / string / 필수 |
| JSON | operationId / string / 필수 |
| JSON | version / string / 필수 |
| JSON | interfaceId / string / 필수 |
| JSON | actionHash / string / 필수 |
| JSON | ssn / string / 선택 |
| JSON | iPin / string / 선택 |
| JSON | code / string / 필수 |
| JSON | usage / string / 필수 |
| JSON | content / string / 필수 |

응답: 200, 409, 400, 401, 403, 502, 503, 500 (그 외 오류는 공통 오류 규격 참조)

ssn/iPin 중 하나 이상 필요. code/usage/content 필수이며 각 고객 대조값 최대2048자입니다. actionHash는43자 base64url 형식, interfaceId는 서버 허용 목록에 있어야 합니다.

200 응답: {"authReqId":"ar_...", "sdkInput":"...", "expiresAt":1792455000000}
같은 회원·채널·thread·업무 범위의 key와 내용은 같은 등록을 반환합니다. 내용 변경은409입니다. 한 업무의 복수 인증은 서로 다른 key로 등록합니다.

## 로컬 검증 및 배포 전 확인

offline 프로필은 메모리 세션 저장소와 PFC mock을 사용합니다. 앱 재시작 시 세션이 사라집니다. 채팅은 B/E 또는 mock 서버가 필요하며 클릭은 GW 로그로 확인합니다.

PFC/SDK·세션 서비스 원자성·Redis/Hazelcast 장애 전환·B/E 소유권·운영 로그 수집·iOS 웹뷰 쿠키는 별도 연동 검증 대상입니다. 실고객 대조값이나 서비스 자격증명을 예제·로그에 기록하지 않습니다.